FLOWGUARD™ SECURITY VERIFICATION PLATFORM

E-Commerce Transactional Security & Business Logic Assessment Report

Autonomous Empirical Verification of Transactional Invariants & State Machine Integrity

Target Platform URL:	**http://127.0.0.1:5000**
Target Operating Mode:	**VULNERABLE**
Assessment Identifier:	`fg-asm-8fa419ba4029`
Assessment Execution Time:	2026-11-04T18:24:32 UTC
PNRI Score & Risk Band:	**88.0% — CRITICAL**
Assessment Completeness:	**85.7% (INCOMPLETE (WARNING))**

Platform-Normalized Risk Index (PNRI)

CONFIDENTIALITY NOTICE & DATA INTEGRITY:
This document contains proprietary security evaluation data generated by the FLOWGUARD Assessment Engine. All evidentiary traces, HTTP request headers, authorization tokens, administrative keys, and synthetic credentials have been strictly sanitized and redacted in accordance with automated security policy.

1. Executive Summary

FLOWGUARD conducted an automated, empirical security assessment of the target e-commerce application to verify transactional integrity and business-logic invariants across 7 critical attack surfaces: payment state bypass (TC-01), coupon reuse (TC-02), idempotent checkout replay (TC-03), order direct object references (TC-04), workflow lifecycle state transitions (TC-05), high-concurrency inventory races (TC-06), and client-side price tampering (TC-07).

Assessment against the **VULNERABLE** operating mode confirmed **6 critical/high-severity business-logic vulnerabilities**, resulting in a Platform-Normalized Risk Index (PNRI) score of **88.0% (CRITICAL)**. The target demonstrated confirmed transactional failures including: unpaid order confirmation, duplicate checkout generation, horizontal tenant IDOR leakage, illegal workflow state skipping, inventory over-allocation under concurrent load, persistence of tampered client prices. Immediate code-level remediation is required before production deployment.

Unverified Scenarios: Evaluation of 1 scenario(s) [TC-02 (Global Single-Use Coupon Reuse)] returned inconclusive results due to unmet preconditions or environment state. These unverified scenarios contribute zero confirmed risk to the PNRI score and are **never classified as confirmed vulnerabilities**, but reduce overall assessment completeness to 85.7%.

■■ INCOMPLETE ASSESSMENT WARNING (Completeness: 85.7%):
One or more scenario evaluations encountered execution errors or returned inconclusive results. Under FLOWGUARD security policy, **AN INCOMPLETE ASSESSMENT CAN NEVER BE CERTIFIED AS SECURE**. The reported risk score reflects only confirmed vulnerabilities; unverified scenarios may harbor undetected critical risks.

2. Assessment Scope & PNRI Risk Quantification

Assessment Identifier	`fg-asm-8fa419ba4029`	**Target URL**	http://127.0.0.1:5000
Target Mode	**VULNERABLE**	**Completeness**	85.7%
Start Time (UTC)	2026-11-04T18:24:32	**End Time (UTC)**	2026-11-04T18:24:37
Raw Risk Score	**110 / 125**	**PNRI Normalized**	**88.0% (Critical)**

Platform-Normalized Risk Index (PNRI) Methodology:
PNRI quantifies cumulative business logic risk normalized to a 0.0 – 100.0 scale using the formula: PNRI = (Confirmed Raw Weights / 125) × 100. Scenario weights align strictly with severity: Critical = 25 pts (TC-01, TC-04) and High = 15 pts (TC-02, TC-03, TC-05, TC-06, TC-07). Risk bands: **Low (0.0–19.9)**, **Moderate (20.0–49.9)**, **High (50.0–74.9)**, and **Critical (75.0–100.0)**.

3. Scenario Results & Invariant Invariants (TC-01 – TC-07)

Each security scenario verifies a foundational e-commerce invariant. A status of **PASS** indicates the invariant held firm (attacks blocked or expected baseline behavior observed). A status of **FAIL** confirms an exploitable business-logic violation. Statuses of **ERROR** or **INCONCLUSIVE** denote unresolved executions and reduce completeness.

ID	Scenario / Invariant Verified	Status	Time	Observed Behavioral Summary
TC-01	Payment Bypass Detection	**FAIL**	613ms	Admin verification confirms an unpaid order reached CONFIRMED.
TC-02	Global Single-Use Coupon Reuse	**INCONCLUSIVE**	7ms	Coupon 'CYBERSEC20' is already exhausted, inactive, or previously redeemed.
TC-03	Duplicate Order Creation / Checkout Idempotency	**FAIL**	629ms	Duplicate order creation confirmed: sequential checkout with the same idempotency key created distinct orders #37 and #38.
TC-04	Order IDOR / Unauthorized Cross-User Access	**FAIL**	1235ms	Vulnerable mode permitted unauthorized user B to access victim user A's order details; admin verification confirms user A owns the order.
TC-05	Invalid Workflow Transitions / State Machine Enforcement	**FAIL**	768ms	Vulnerable mode permitted multiple invalid workflow transitions: unpaid confirmation, repeated confirmation on terminal state, repeated cancellation on terminal state, and resurrection of a cancelled order; admin ground truth confirms illegal state mutations.
TC-06	Concurrent Checkout Race Condition / Idempotency Invariant	**FAIL**	687ms	Vulnerable mode permitted duplicate order creation under concurrent same-key checkout; admin ground truth confirms 4 distinct orders committed with identical key 'tc06-shared-76505a9ce79347bd9b197af13e4c5513'.
TC-07	Client-Side Price Tampering / Server-Authoritative Pricing	**FAIL**	595ms	Vulnerable mode permitted client-side price tampering: order #46 stored client-submitted total of 100 minor units instead of canonical catalog price 450000 minor units.

4. Confirmed Vulnerability Findings & Technical Analysis

FG-TC01-001: Unpaid Order Confirmation via State Transition Bypass	**CRITICAL**
Scenario Origin	TC-01
Common Weakness	**CWE-840: Business Logic Errors**
Technical Description	The order confirmation endpoint allows an order in PENDING_PAYMENT state to transition directly to CONFIRMED without requiring or validating a corresponding successful payment record. CWE: CWE-840 (Business Logic Errors)
Business & Financial Impact	Attackers can obtain goods or services without fulfilling monetary payment obligations, leading to direct financial loss and uncollectible inventory fulfillment.
Recommended Remediation	Require authoritative payment verification before allowing order status transitions. Validate that a completed payment record exists and is cryptographically tied to the order ID.

Evidence References	`Step 1: /vulnerable/api/auth/register`
	`Step 2: /vulnerable/api/auth/login`
	`Step 3: http://127.0.0.1:5000/vulnerable/api/products`
	`Step 4: http://127.0.0.1:5000/vulnerable/api/cart/items`
	`Step 5: http://127.0.0.1:5000/vulnerable/api/orders/checkout`
	`Step 6: http://127.0.0.1:5000/vulnerable/api/orders/36/confirm`

FG-TC03-001: Checkout Replay Vulnerability / Lack of Idempotency Enforcement	HIGH
Scenario Origin	TC-03
Common Weakness	**CWE-294: Authentication Bypass by Capture-replay**
Technical Description	The checkout endpoint does not enforce idempotency keys, allowing sequential replayed checkout requests with identical payload to generate duplicate orders and duplicate charges. CWE: CWE-294 (Authentication Bypass by Capture-replay)
Business & Financial Impact	Network retries or replayed checkout submissions result in duplicate order fulfillment, unintended inventory allocation, and customer billing disputes.
Recommended Remediation	Implement idempotent request handling with a unique database constraint on the idempotency key. Return the cached order response for identical requests and HTTP 409 Conflict for mismatched payloads.

Evidence References	`Step 1: http://127.0.0.1:5000/vulnerable/api/products`
	`Step 2: http://127.0.0.1:5000/vulnerable/api/cart/items`
	`Step 3: http://127.0.0.1:5000/vulnerable/api/orders/checkout`
	`Step 4: http://127.0.0.1:5000/api/admin/verify/order/vulnerable/37`
	`Step 5: http://127.0.0.1:5000/vulnerable/api/cart/items`
	`Step 6: http://127.0.0.1:5000/vulnerable/api/orders/checkout`

FG-TC04-001: Insecure Direct Object Reference (IDOR) on Order Details	CRITICAL
Scenario Origin	TC-04
Common Weakness	**CWE-639: Authorization Bypass Through User-Controlled Key**
Technical Description	The order retrieval endpoint fails to enforce resource ownership validation, allowing any authenticated user to view complete order data and customer metadata belonging to another user. CWE: CWE-639 (Authorization Bypass Through User-Controlled Key)
Business & Financial Impact	Severe breach of customer confidentiality, unauthorized disclosure of PII, shipping addresses, purchased items, and transaction metadata to unprivileged tenants.
Recommended Remediation	Strictly enforce tenant authorization checks at the data layer (e.g. order.user_id == current_user.id). Return HTTP 403 or 404 for unauthorized access attempts without leaking order existence.

Evidence References	`Step 1: http://127.0.0.1:5000/vulnerable/api/products`
	`Step 2: http://127.0.0.1:5000/vulnerable/api/cart/items`
	`Step 3: http://127.0.0.1:5000/vulnerable/api/orders/checkout`
	`Step 4: http://127.0.0.1:5000/api/admin/verify/order/vulnerable/39`
	`Step 5: http://127.0.0.1:5000/vulnerable/api/orders/39`
	`Step 6: http://127.0.0.1:5000/api/admin/verify/order/vulnerable/39`

FG-TC05-001: Illegal Order State Machine Transitions and Workflow Bypass	HIGH
Scenario Origin	TC-05
Common Weakness	**CWE-840: Business Logic Errors**
Technical Description	The order workflow permits invalid state transitions, including confirming unpaid orders, resurrecting canceled orders, and applying conflicting state mutations out of sequence. CWE: CWE-840 (Business Logic Errors)
Business & Financial Impact	Order state machine corruption, inconsistent order statuses, bypassed operational controls, and unauthorized order fulfillment after cancellation.
Recommended Remediation	Implement a strict finite state machine (FSM) defining valid transitions (e.g., CART -> PENDING -> PAID -> CONFIRMED). Explicitly reject illegal transition attempts with HTTP 400 Bad Request.

Evidence References	`Step 1: http://127.0.0.1:5000/vulnerable/api/products`
	`Step 2: http://127.0.0.1:5000/vulnerable/api/cart/items`
	`Step 3: http://127.0.0.1:5000/vulnerable/api/orders/checkout`
	`Step 4: http://127.0.0.1:5000/api/admin/verify/order/vulnerable/40`
	`Step 5: http://127.0.0.1:5000/api/admin/verify/payment/vulnerable/40`
	`Step 6: http://127.0.0.1:5000/vulnerable/api/orders/40/confirm`

FG-TC06-001: Concurrent Checkout Race Condition Permitting Duplicate Order Creation	HIGH
Scenario Origin	TC-06
Common Weakness	**CWE-362: Concurrent Execution using Shared Resource with Improper Synchronization ('Race Condition')**
Technical Description	The checkout endpoint is vulnerable to race conditions under concurrent execution. Simultaneous checkout requests bypass application-level uniqueness checks before transactions commit, creating duplicate orders from a single cart. CWE: CWE-362 (Concurrent Execution using Shared Resource with Improper Synchronization ('Race Condition'))
Business & Financial Impact	Inventory exhaustion, duplicate orders created without corresponding inventory or payment, and database state inconsistency under high load or adversarial concurrency.
Recommended Remediation	Enforce concurrency isolation using database row-level locking (SELECT FOR UPDATE), unique constraints on active carts/idempotency keys, or distributed locks around the checkout critical section.

Evidence References	`Step 1: http://127.0.0.1:5000/vulnerable/api/products`
	`Step 2: http://127.0.0.1:5000/vulnerable/api/cart/items`
	`Step 3: http://127.0.0.1:5000/vulnerable/api/orders/checkout`
	`Step 4: http://127.0.0.1:5000/vulnerable/api/orders/checkout`
	`Step 5: http://127.0.0.1:5000/vulnerable/api/orders/checkout`
	`Step 6: http://127.0.0.1:5000/vulnerable/api/orders/checkout`

FG-TC07-001: Client-Side Order Total Parameter Tampering	HIGH
Scenario Origin	TC-07
Common Weakness	**CWE-602: Client-Side Enforcement of Server-Side Security**
Technical Description	The checkout endpoint accepts and persists client-submitted order total parameters, overriding the authoritative server-side calculated pricing based on canonical product catalog unit prices. CWE: CWE-602 (Client-Side Enforcement of Server-Side Security)
Business & Financial Impact	Attackers can arbitrarily manipulate purchase prices (e.g., buying expensive merchandise for $1.00), causing catastrophic merchant revenue loss.
Recommended Remediation	Calculate all order prices, discounts, and totals exclusively on the server side using canonical catalog records. Completely ignore or reject client-supplied total_amount parameters.

Evidence References	`Step 1: http://127.0.0.1:5000/vulnerable/api/products`
	`Step 2: http://127.0.0.1:5000/vulnerable/api/cart/items`
	`Step 3: http://127.0.0.1:5000/vulnerable/api/orders/checkout`
	`Step 4: http://127.0.0.1:5000/api/admin/verify/order/vulnerable/46`
	`Step 5: http://127.0.0.1:5000/vulnerable/api/cart`
	`Step 6: /vulnerable/api/auth/logout`

5. Assessment Limitations & Final Conclusion

Assessment Scope & Limitations:
This security evaluation was performed strictly against HTTP API transaction routes and business logic invariants. It specifically verifies state transitions, single-use constraints, idempotency enforcement, tenant isolation, race serialization, and pricing calculations. This assessment does not substitute for full infrastructure penetration testing, operating system audits, DDoS resilience profiling, or third-party payment processor compliance certifications (e.g. PCI-DSS Level 1).

Conclusion: The target system in **VULNERABLE** mode exhibited a critical breakdown of transactional business invariants, resulting in a **PNRI score of 88.0% (CRITICAL)**. The findings present severe risks of unauthorized fulfillment, inventory leakage, and financial loss. All recommended code-level remediations should be prioritized before opening these endpoints to untrusted traffic.

Assessment Verification Engine:	FLOWGUARD v1.0.0 — Autonomous Security Suite
Report Generation Timestamp:	2026-11-04T19:59:19 UTC
Evaluation Target Base URL:	http://127.0.0.1:5000
Classification:	STRICTLY CONFIDENTIAL — SANITIZED SECURITY RECORD